

Capitolul 2

Tema 2

Algoritm pentru penetrare fizică – Test de securitate „Simir” SRL

1. Faza de planificare și cercetare (OSINT)

1.1. Obiectivele principale:

- Să pătrund în sediul „Simir” SRL, să accesez biroul contabilului șef și să obțin acces la computerul acestuia.
- Să simulez un atac cât mai realist și credibil, fără a ridica suspiciuni.

1.2. Colectarea de informații (OSINT):

1. Date despre companie:

- Adresa exactă a sediului principal din Iași (identificată pe Google Maps).
- Detalii despre securitatea fizică:
 - Încuietoare magnetică la intrare.
 - Alarmă activă, fără supraveghere video externă.
- Program de lucru al companiei: 8:00-17:00.

2. Analiza angajaților:

- Căutarea angajaților pe LinkedIn și Facebook:
- Identificarea contabilului șef – obținerea numelui, adresei de e-mail și altor informații relevante (hobby-uri, interese).
- Colectarea numelor unor angajați pentru a le folosi în conversații (nume comune din rețele sociale).

3. Parteneri și colaboratori:

- Verificarea posibilelor companii partenere pentru crearea unei identități false (ex. o firmă de suport IT sau audit financiar).

4. Structura clădirii:

- Identificarea intrărilor secundare (dacă există) sau a posibilelor vulnerabilități fizice.
- Observarea mișcărilor angajaților din zona clădirii (prin vizite discrete la fața locului).

2. Faza de pregătire

2.1. Stabilirea unei identități false (legendă):

- Rol: Tehnician IT extern de la o firmă de suport tehnic fictivă, „ProTech IT Solutions”.
- Motivație: Rezolvarea unei probleme tehnice urgente raportate de către conducerea companiei.
- Echipament și accesorii:
 - Legitimăție falsă cu numele și logo-ul firmei „ProTech IT Solutions”.
 - geantă de tip tehnic (laptop, cabluri, unelte aparent necesare pentru verificarea sistemelor IT).
 - Stick USB pregătit cu un script pentru recoltarea credențialelor.
 - Smartphone conectat la rețea pentru verificarea informațiilor în timp real.

2.2. Alegerea momentului pentru acțiune:

- Zi: Miercuri – mijlocul săptămânii, când activitatea este constantă, dar nu intensă.
- Ora: 14:00-15:00 – după prânz, angajații sunt mai relaxați, iar fluxul de vizitatori este minim.
- Context: Majoritatea birourilor sunt ocupate, dar contabilul șef ar putea fi temporar absent (de exemplu, într-o întâlnire).

2.3. Planificarea intrării în clădire:

- Tehnica „tailgating”: Mă poziționez aproape de un angajat care intră în clădire și pretind că sunt grăbit sau că „mi-am uitat cardul de acces”.
- Alternative:
 - Sun la interfon și menționez că am fost trimis de un nume familiar companiei (ex. „Domnul Popescu” de la IT).
 - Folosesc o listă cu nume colectate din cercetarea OSINT pentru a crea o aparență de autenticitate.

3. Faza de execuție

3.1. Intrarea în clădire:

- Scenariu: Pretind că sunt tehnician IT și că trebuie să verific o problemă urgentă de securitate.
- Răspunsuri la întrebări comune:

„De ce nu știm despre această intervenție?”

„Este un test de securitate surpriză pentru a ne asigura că sistemele sunt sigure.”

„Aveți o aprobare scrisă?”

„Este o situație urgentă discutată direct cu conducerea. Puteți verifica cu Domnul Popescu din IT.”

3.2. Găsirea biroului contabilului șef:

- Identific biroul pe baza ușilor marcate sau întreb angajații într-un mod casual.
- Pretind că problema tehnică este localizată în computerul contabilului șef și că trebuie să efectuez o verificare.

3.3. Accesarea computerului:

- Introduc stick-ul USB cu software-ul pregătit pentru colectarea credentialelor (ex. „USB Rubber Ducky” sau „Keylogger”).
- Metodă alternativă: Dacă computerul este deja accesat, notez informațiile afișate pe ecran (ex. parole salvate sau documente deschise).

3.4. Crearea unei diversiuni:

- Dacă sunt supravegheat, creez o situație pentru a distrage atenția (ex. „Routerul poate cauza problema, verificați în camera alăturată!”).

4. Faza de extracție

4.1. Finalizarea acțiunii:

- După obținerea credentialelor, închid computerul și notez observațiile pentru raport.
- Mulțumesc angajaților pentru colaborare și le ofer datele mele de contact false pentru „situații ulterioare”.

4.2. Părăsirea clădirii:

- Ies discret din clădire, fără să atrag atenția, folosind aceeași metodă de intrare.

5. Posibile obstacole și planuri de rezervă

- Dacă sunt întrebat detalii tehnice: Folosesc jargon IT simplu și general pentru a impresiona („analizăm logurile sistemului pentru breșe”).
- Dacă alarma se activează: Pretind că am fost instruit greșit și aștept până când alarma este dezactivată.
- Dacă cineva solicită verificarea identității mele: Intru într-o conversație politică, cerând angajatului să confirme cu „Domnul Popescu” fictiv.

E-mail de phishing

Subiect:  [Alertă critică] Tentativă de acces neautorizat la contul dvs.

Textul e-mailului:

Stimat/ă [Nume Contabil Șef],

Sistemul de monitorizare al companiei a detectat o tentativă neautorizată de acces la contul dvs. din locația [localizare IP fictivă, ex: Moscova, Rusia]. Pentru a vă proteja informațiile critice, contul dvs. a fost temporar restricționat.

 Această situație este considerată critică deoarece încercările de acces au implicat mai multe parole greșite. Posibil ca datele dvs. să fi fost compromise.

Vă rugăm să verificați imediat activitatea contului și să confirmați dacă recunoașteți această încercare. Accesați linkul de mai jos pentru a vă securiza contul și a reseta parola:

[Link fals personalizat - ex: www.simir-protectie-cont.com]

Dacă nu veți răspunde în următoarele 2 ore, accesul contului va fi suspendat, iar departamentul IT va fi obligat să blocheze toate operațiunile contabile asociate acestuia.

Pentru asistență suplimentară, contactați urgent echipa IT la suport@simir-srl.com sau la telefonul 0765368968 [număr fictiv].

Notă: Aceasta este o notificare automată generată de sistemul de protecție al companiei. Nerespectarea acestei alerte poate duce la pierderea accesului permanent la cont.

Cu respect,

Echipa IT - Simir SRL

Departamentul de Securitate a Datelor

Elemente de manipulare din e-mail:

- Sentiment de urgență crescut:
 - Menționarea unui interval de timp limitat (2 ore).
 - Implicarea unor consecințe grave (blocarea contului, suspendarea operațiunilor financiare).
- Crearea de teamă:
 - Referința la o locație suspicioasă (ex: Moscova, Rusia) pentru a sugera un atac străin.
 - Ideea că datele contabile critice ar putea fi deja compromise.
- Conținut credibil:
 - Oferirea unui link aparent legitim, cu o adresă similară cu domeniul companiei.
 - Menționarea unei echipe de suport IT și a unui număr de contact fictiv pentru a crea autenticitate.